InternNova Internship Program

Week 3 Assignment

Malware, Phishing & Security Awareness

Task 1 & Task 2

Malware, Phishing & Security Awareness

Intern Name: NAJMUDEEN S
Internship: InternNova
Week: 3
Assignment: Malware, Phishing & Security Awareness
Month: October 2026

Table of Contents

1 Task 1: Understanding Malware **1**

1.1 Introduction . . . 1
1.2 Virus . . . 1
1.3 Worm . . . 3
1.4 Trojan . . . 5
1.5 Ransomware . . . 7
1.6 Spyware . . . 9
1.7 Overall Malware Diagrams . . . 12
1.8 Malware Comparison . . . 13
1.9 Mini Practical / Try It Yourself . . . 13
1.10 Cybersecurity Connection . . . 14
1.11 Security Risks and Protection . . . 14
1.12 Quick Check . . . 14
1.13 Task 1 Summary . . . 14

2 Task 2: Understanding Phishing **15**

2.1 Introduction . . . 15
2.2 What is Phishing? . . . 15
2.3 Email Phishing . . . 17
2.4 Smishing . . . 19
2.5 Vishing . . . 21
2.6 Fake Website / Link Phishing . . . 23
2.7 Five Common Signs of a Phishing Message . . . 25
2.8 Phishing Types Comparison . . . 26
2.9 Mini Practical / Try It Yourself . . . 26
2.10 Cybersecurity Connection . . . 26
2.11 Security Risks and Protection . . . 27
2.12 Safe Response to a Suspicious Message . . . 28
2.13 Quick Check . . . 29
2.14 Task 2 Summary . . . 29

3 Task 3: Identify a Phishing Message **29**

3.1 Introduction . . . 29
3.2 Phishing Message Analysis Process . . . 30
3.3 Phishing Identification Checklist . . . 31
3.4 Public Example 1: Fake MetaMask Phishing Email . . . 31
3.5 Public Example 2: Fake Direct-Deposit Phishing Email . . . 32
3.6 Comparison of the Two Phishing Examples . . . 33
3.7 Cybersecurity Connection . . . 33
3.8 Security Risks and Basic Protection . . . 33
3.9 Quick Check . . . 34
3.10 Task 3 Summary . . . 35

4 Task 4: Malware Prevention **35**

4.1 Introduction . . . 35
4.2 Malware Prevention – Overall Security Process . . . 35
4.3 Ten Malware Prevention Practices . . . 36
4.4 Detailed Explanation of Five Practices . . . 38
4.5 Malware Backup and Recovery Process . . . 39
4.6 Safe Software Download and Installation . . . 40
4.7 Cybersecurity Connection . . . 41
4.8 Security Risks and Basic Protection . . . 41
4.9 Mini Practical: Safe Software Verification . . . 41
4.10 Quick Check . . . 42
4.11 Task 4 Summary . . . 42
4.12 Documentation References . . . 43
4.13 YouTube Learning References . . . 43

5 Task 5: Security Awareness Scenario **43**

5.1 Introduction . . . 43
5.2 Security Awareness Scenario . . . 43
5.3 Security Awareness Scenario Response Process . . . 44
5.4 What Type of Attack Is This? . . . 45
5.5 Warning Signs . . . 45

5.6 What Should the Recipient Do? 45
5.7 What Should the Recipient NOT Do? 45
5.8 Reporting Method 46
5.9 Cybersecurity Connection 46
5.10 Security Risks and Protection 46
5.11 Mini Practical / Try It Yourself 46
5.12 Documentation References 47
5.13 YouTube Learning Reference 47
5.14 Quick Check 47
5.15 Task 5 Summary 48

6 Task 6: Security Awareness Activity 49
6.1 Cyber Security Awareness Poster 49
6.2 Poster Safety Tips 50
6.3 Why These Tips Matter 50
6.4 Suggested Awareness Activity 50
6.5 Cybersecurity Connection 50
6.6 Quick Check 51
6.7 Task 6 Summary 51
6.8 Documentation References 51

1 Task 1: Understanding Malware

1.1 Introduction

Malware is short for malicious software. It refers to software designed to perform unauthorized or harmful actions on a computer, mobile device, network, or information system. Different malware types behave differently: some infect files, some spread between systems, some disguise themselves as legitimate software, some restrict access to data, and some secretly collect information.

1.2 Virus

1.2.1 Definition

A virus is malware that attaches itself to a file or program and can replicate when the infected content is executed.

1.2.2 How It Works

A typical virus becomes active when an infected file is executed. The malicious code can then modify or attach itself to other files, allowing the infection to continue when those files are opened or shared.

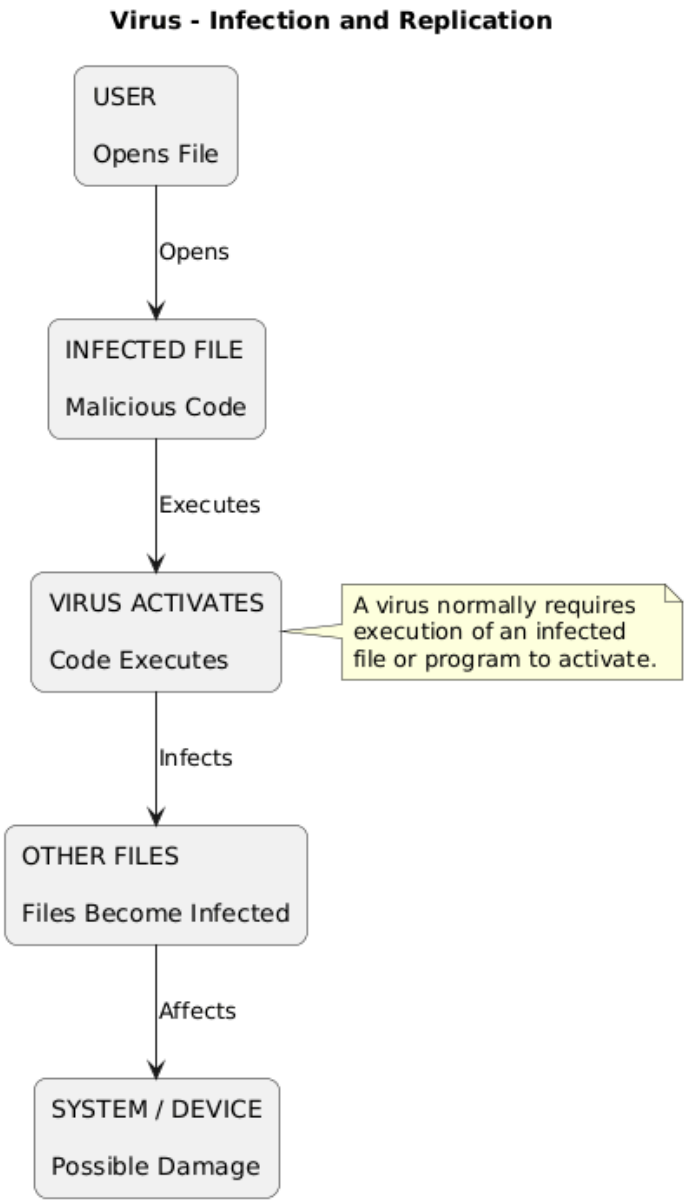


Figure 1: Virus Infection and Replication

1.2.3 Real-World Example

CIH, also known as the Chernobyl virus, is a historical example of a computer virus associated with infected executable files and destructive activity.

1.2.4 Cybersecurity Connection

Viruses are relevant to endpoint security because they can modify legitimate files and affect system integrity. Analysts may investigate antivirus detections, unusual file modifications, suspicious processes, and unexpected system behavior.

1.2.5 Security Risk and Protection

Potential Risk: An infected file can spread malicious code when it is executed or shared.

Protection:

- Use reputable security software.
- Keep systems updated.
- Avoid unexpected attachments.
- Download software from trusted sources.
- Scan suspicious files.

Reference Basis: Authoritative cybersecurity guidance

Reference Paper / Standard: Relevant guidance or standard

Learning Video: Educational cybersecurity video

View Reference View Standard Watch on YouTube

1.3 Worm

1.3.1 Definition

A worm is malware that can replicate itself and spread from one system to another without requiring the user to manually copy it.

1.3.2 How It Works

A worm may search for reachable or vulnerable systems and attempt to spread automatically. An infected system can then continue the propagation process.

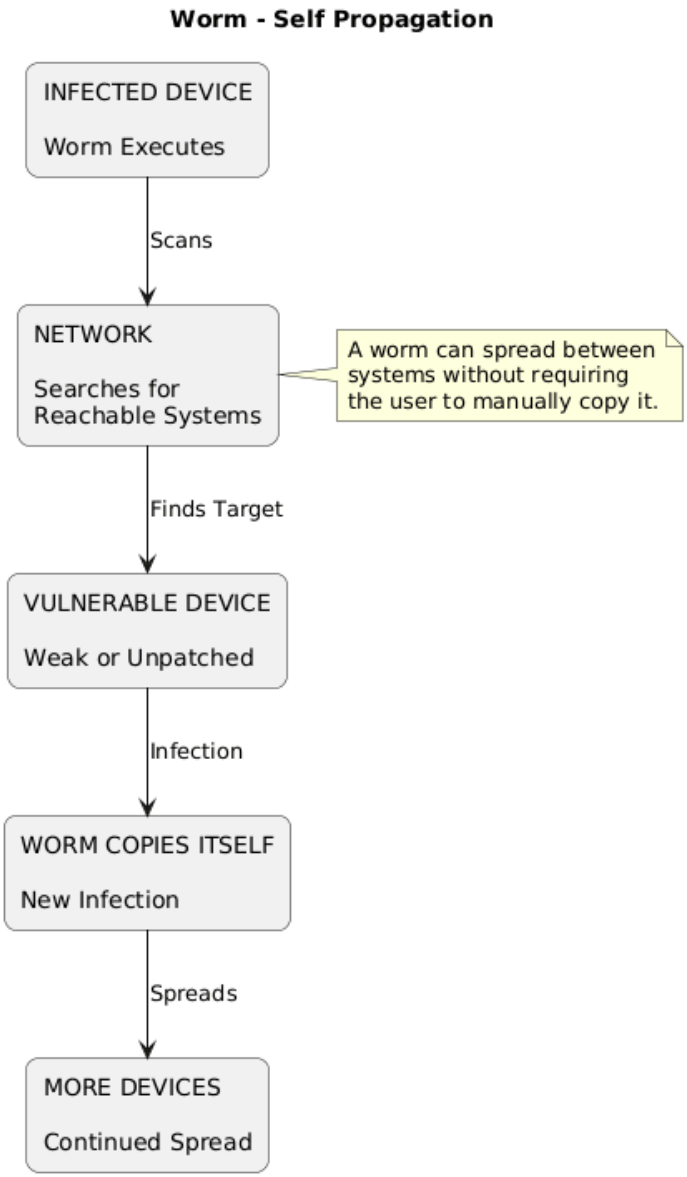


Figure 2: Worm Self-Propagation

1.3.3 Real-World Example

Conficker is a well-known computer worm that spread through Windows systems by exploiting vulnerabilities and weak configurations.

1.3.4 Cybersecurity Connection

Worms are important in network security because they can spread rapidly. Analysts may monitor unusual network traffic, repeated connection attempts, vulnerability exploitation, and unexpected endpoint behavior.

1.3.5 Security Risk and Protection

Potential Risk: A worm can automatically spread across vulnerable systems.

Protection:

- Apply security updates.
- Use firewalls.
- Disable unnecessary services.
- Segment networks where appropriate.
- Monitor unusual network activity.

Reference Basis: Authoritative cybersecurity guidance

Reference Paper / Standard: Relevant guidance or standard

Learning Video: Educational cybersecurity video

View Reference View Standard Watch on YouTube

1.4 Trojan

1.4.1 Definition

A Trojan is malware that disguises itself as legitimate or useful software to trick a user into installing or executing it.

1.4.2 How It Works

A Trojan may be distributed through a fake application, document, attachment, or apparently legitimate file. After execution, it can perform unauthorized actions.

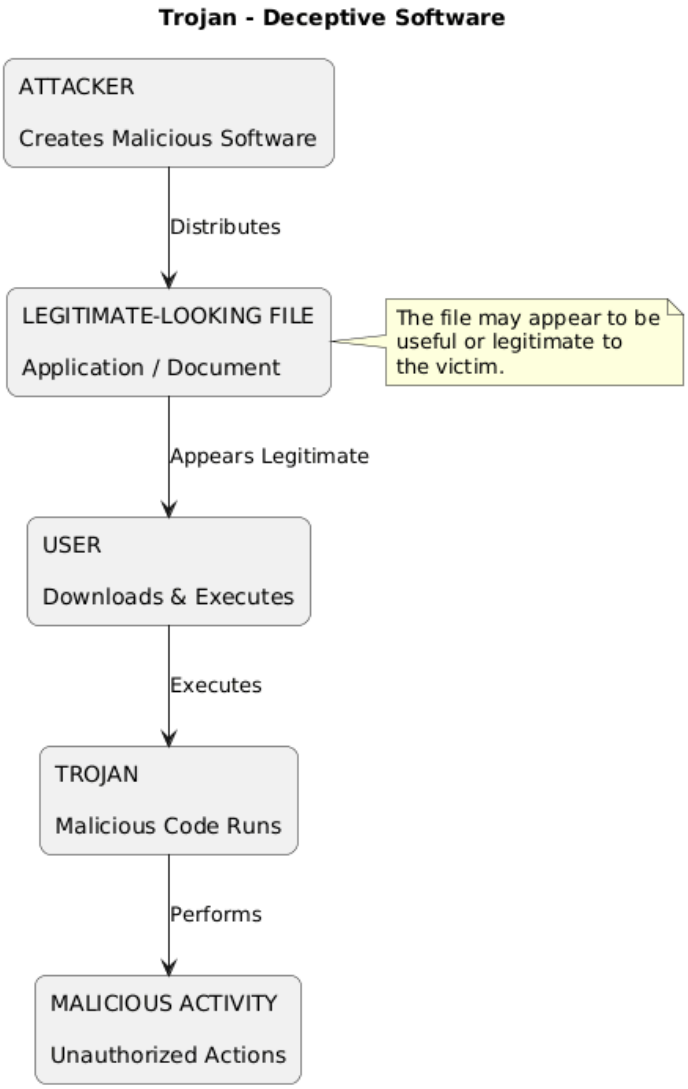


Figure 3: Trojan Deceptive Software Process

1.4.3 Real-World Example

Zeus is a well-known example of malware associated with Trojan-based distribution and theft of sensitive information such as banking credentials.

1.4.4 Cybersecurity Connection

Trojans are important because they often depend on deception or social engineering. Analysts may investigate unexpected installations, suspicious processes, unusual connections, and endpoint alerts.

1.4.5 Security Risk and Protection

Potential Risk: A user may unknowingly install malicious software because it appears legitimate.

Protection:

- Use trusted software sources.
- Avoid pirated or modified software.
- Verify software publishers.
- Use endpoint security.
- Avoid unexpected attachments.

Reference Basis: Authoritative cybersecurity guidance

Reference Paper / Standard: Relevant guidance or standard

Learning Video: Educational cybersecurity video

View Reference View Standard Watch on YouTube

1.5 Ransomware

1.5.1 Definition

Ransomware is malware that can prevent access to files or systems, commonly by encrypting data, and then demands payment from the victim.

1.5.2 How It Works

Ransomware may enter through a malicious attachment, compromised account, vulnerable service, or another initial access method. It may identify files, encrypt them, and display a ransom demand.

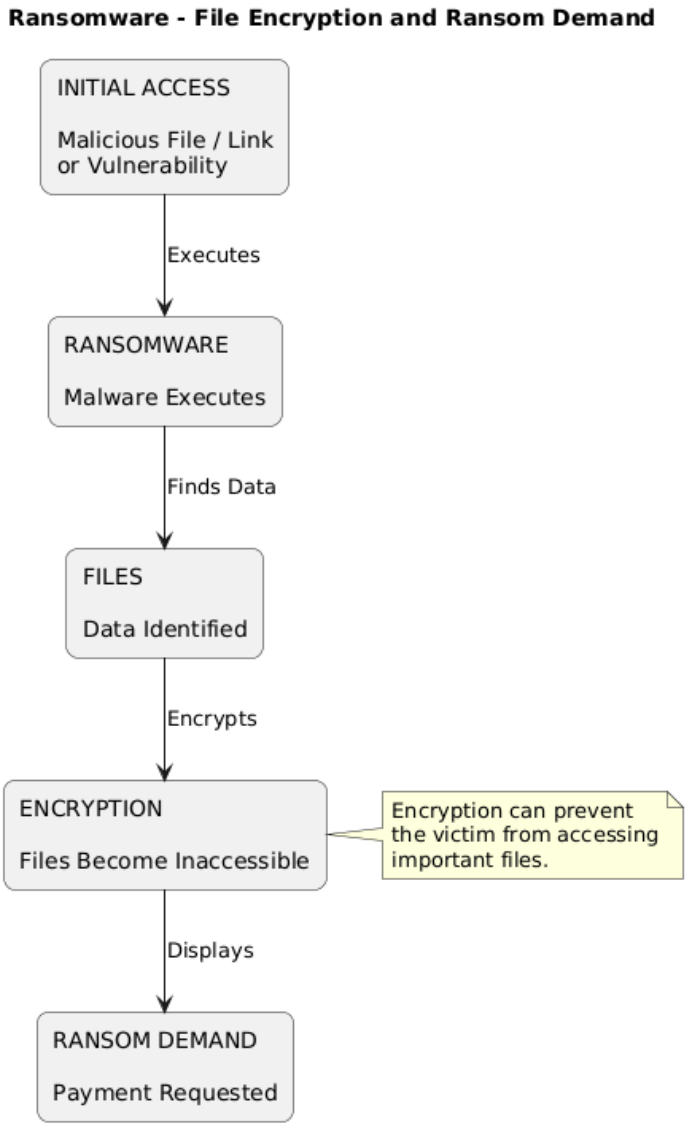


Figure 4: Ransomware File Encryption and Ransom Demand

1.5.3 Real-World Example

WannaCry is a well-known ransomware outbreak that affected computer systems in multiple countries.

1.5.4 Cybersecurity Connection

Ransomware can affect data availability and operations. Security teams may monitor endpoint alerts, file activity, authentication events, backups, and network traffic.

1.5.5 Security Risk and Protection

Potential Risk: Important files may become inaccessible and operations may be disrupted.

Protection:

- Maintain protected backups.
- Patch systems.
- Use endpoint security.
- Restrict unnecessary network access.
- Train users to recognize suspicious links and attachments.

Reference Basis: Authoritative cybersecurity guidance

Reference Paper / Standard: Relevant guidance or standard

Learning Video: Educational cybersecurity video

View Reference View Standard Watch on YouTube

1.6 Spyware

1.6.1 Definition

Spyware is malware designed to operate without the user's knowledge and collect information about user activity or sensitive information.

1.6.2 How It Works

Spyware may run in the background after installation. Depending on its capabilities, it can collect browsing activity, credentials, or other sensitive data and transmit it to an unauthorized party.

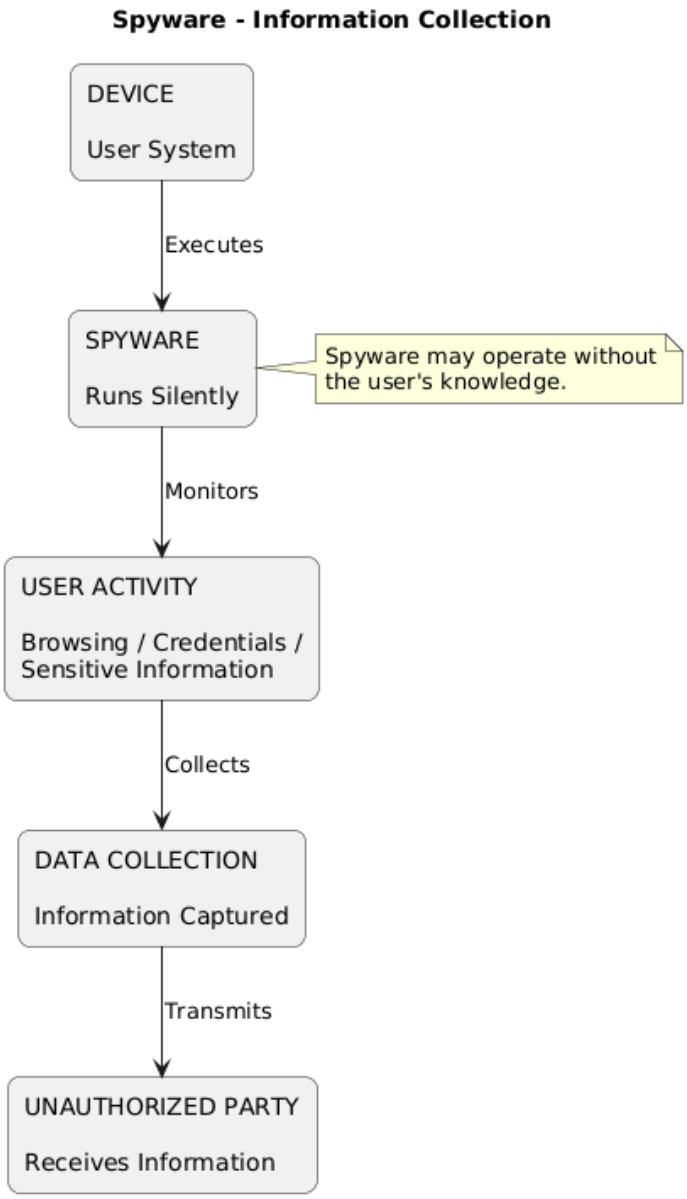


Figure 5: Spyware Information Collection

1.6.3 Real-World Example

Pegasus is an example of sophisticated spyware associated with targeted surveillance of mobile devices.

1.6.4 Cybersecurity Connection

Spyware is relevant to endpoint security and privacy because unauthorized collection can expose sensitive data. Analysts may investigate unusual processes, applications, connections, and endpoint alerts.

1.6.5 Security Risk and Protection

Potential Risk: Sensitive information may be collected without the user's knowledge.

Protection:

- Install trusted applications.
- Keep systems updated.
- Use reputable security software.
- Review applications and permissions.
- Avoid suspicious links and downloads.

Reference Basis: Authoritative cybersecurity guidance

Reference Paper / Standard: Relevant guidance or standard

Learning Video: Educational cybersecurity video

View Reference View Standard Watch on YouTube

1.7 Overall Malware Diagrams

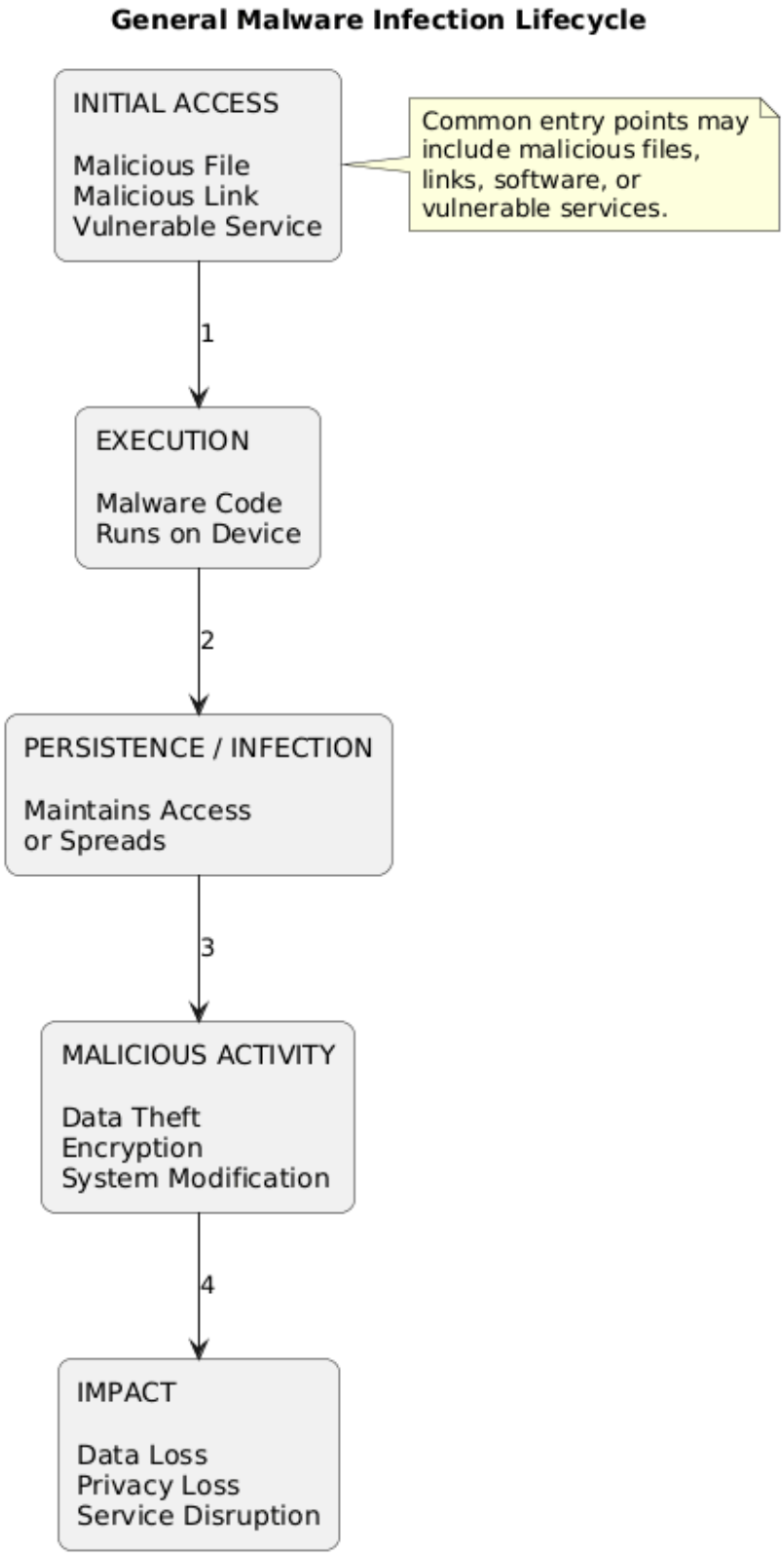


Figure 6: General Malware Infection Lifecycle

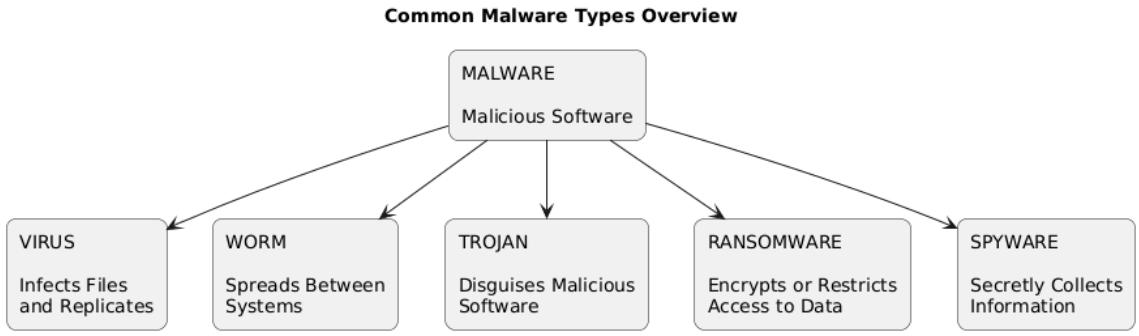


Figure 7: Common Malware Types Overview

1.8 Malware Comparison

Malware	Main Behavior	Typical Impact	Basic Protection
Virus	Infects files and replicates when activated	File/system modification	Updates and security software
Worm	Replicates and spreads between systems	Rapid network/system infection	Patching, firewalls, segmentation
Trojan	Disguises malicious software as legitimate software	Unauthorized activity	Trusted software sources
Ransomware	Encrypts or restricts access to data	Loss of data availability	Backups and patching
Spyware	Secretly collects information	Privacy/information loss	Trusted apps and endpoint security

Table 1: Comparison of Common Malware Types

1.9 Mini Practical / Try It Yourself

A safe malware-awareness activity can be performed without downloading or executing real malware.

1. Open the security settings of your operating system.
2. Check whether real-time protection is enabled.
3. Check the latest security update.
4. Review installed applications.
5. Verify unfamiliar applications before taking action.

Safety Note: Do not download, execute, or interact with real malware for this assignment.

1.10 Cybersecurity Connection

Malware knowledge is important for cybersecurity analysts because malware can affect endpoints, networks, applications, and data. Analysts may use endpoint detection tools, security alerts, logs, network traffic, and file activity to investigate suspicious behavior.

1.11 Security Risks and Protection

Risks: Unauthorized access, information theft, file destruction, loss of data availability, and spread across connected systems.

Protection: Keep systems updated; use reputable security software; maintain protected backups; use strong authentication; use trusted software sources; avoid suspicious attachments and links; monitor unusual activity.

1.12 Quick Check

1. Which malware attaches to files?
2. Which malware spreads automatically?
3. Which disguises itself as legitimate software?
4. Which commonly encrypts data?
5. Which secretly collects information?

Answers:

1. Virus.
2. Worm.
3. Trojan.
4. Ransomware.
5. Spyware.

1.13 Task 1 Summary

Viruses infect files, worms spread between systems, Trojans disguise malicious software, ransomware can restrict access to data, and spyware can secretly collect information. Understanding these types helps users recognize threats and helps cybersecurity professionals investigate malicious activity.

2 Task 2: Understanding Phishing

2.1 Introduction

Phishing is a social-engineering technique in which attackers use deceptive messages, calls, or websites to trick people into revealing sensitive information, clicking harmful links, downloading malicious content, or performing an action that benefits the attacker.

2.2 What is Phishing?

2.2.1 Definition

Phishing uses deceptive communication to trick a victim into providing sensitive information or performing an unsafe action. Attackers commonly impersonate trusted people, companies, services, or organizations.

2.2.2 How a Phishing Attack Works

A typical attack begins when an attacker prepares a deceptive message and delivers it through email, SMS, a phone call, a website, or another communication channel. The victim is encouraged to click, respond, enter credentials, make a payment, or provide sensitive information.

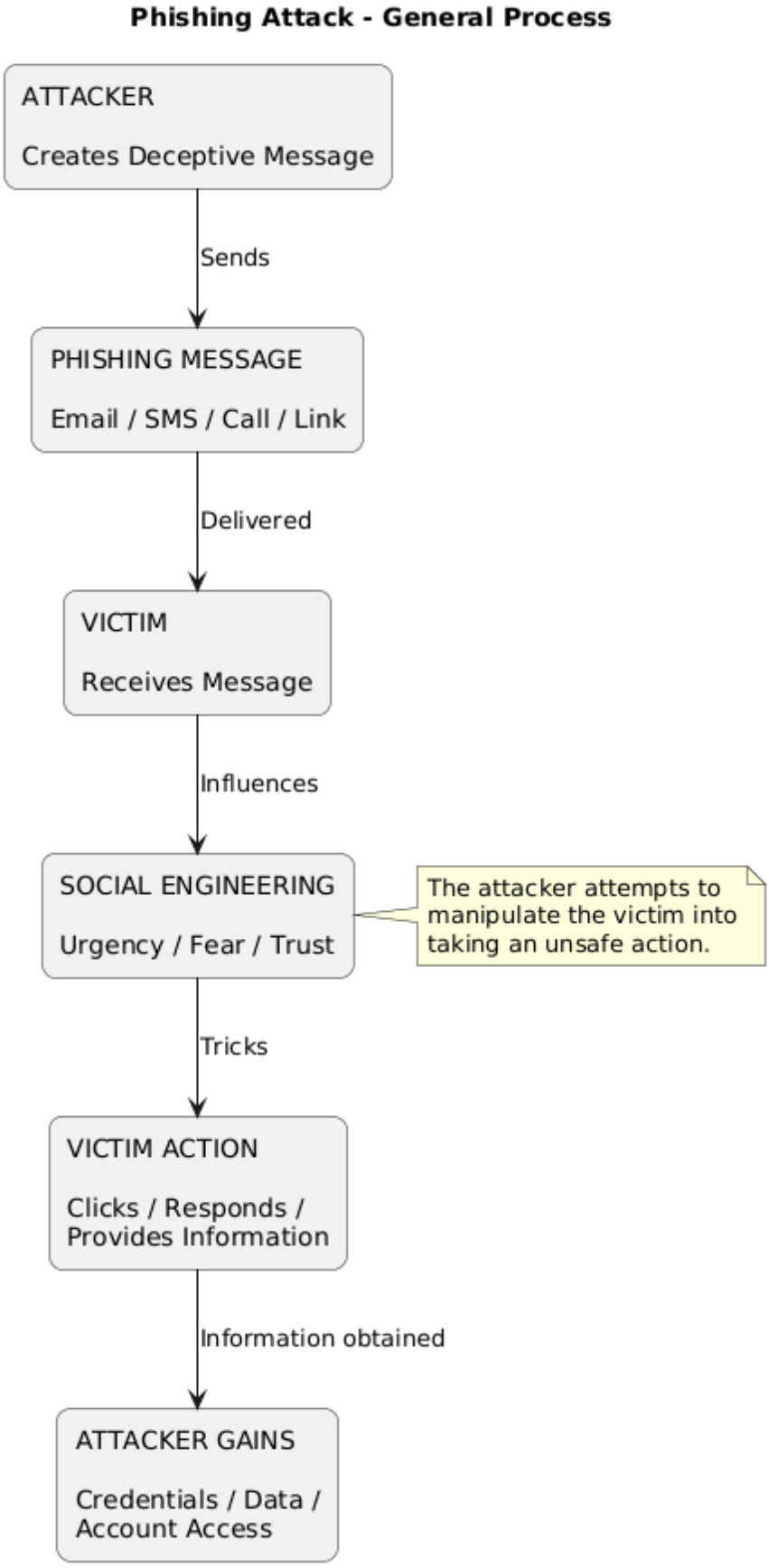


Figure 8: Phishing Attack – General Process

2.2.3 Why Do Attackers Use Phishing?

Attackers use phishing to exploit human decision-making. Successful phishing may steal credentials, obtain personal or financial information, gain account access, deliver malware, redirect users to fraudulent sites, or convince victims to make payments.

Reference Basis: Authoritative cybersecurity guidance

Reference Paper / Standard: Relevant guidance or standard

Learning Video: Educational cybersecurity video

View Reference View Standard Watch on YouTube

2.3 Email Phishing

2.3.1 Definition

Email phishing uses deceptive emails to impersonate trusted organizations, companies, or individuals and persuade the recipient to perform an unsafe action.

2.3.2 How It Works

The attacker sends an email designed to appear legitimate. It may contain a malicious link, attachment, fake login page, payment request, or request for sensitive information.

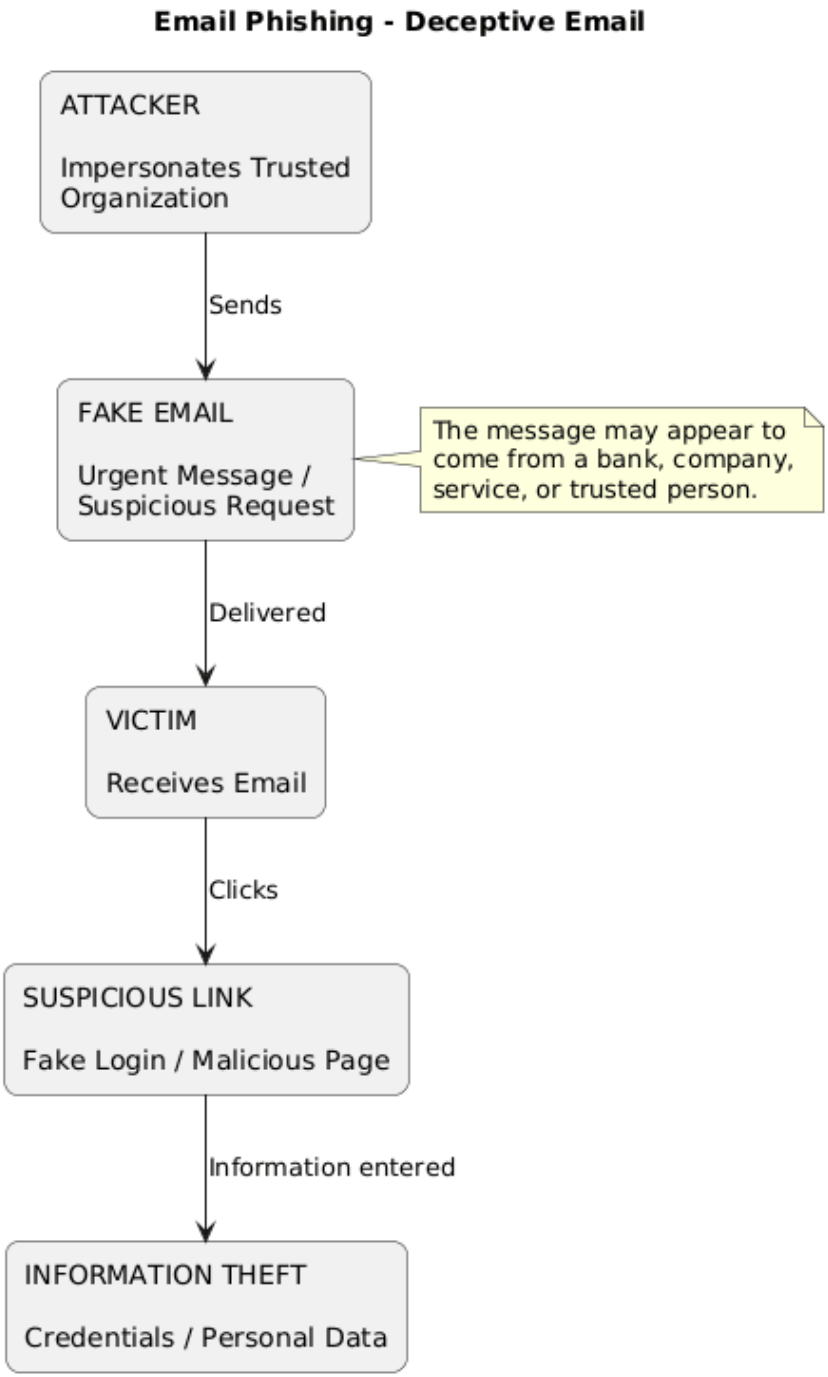


Figure 9: Email Phishing – Deceptive Email

2.3.3 Real-World Example

A user may receive an email appearing to come from a bank claiming that immediate account verification is required and providing a fraudulent login link.

2.3.4 Cybersecurity Connection

Security teams may use email filtering, URL analysis, threat intelligence, and user reporting to identify suspicious messages.

2.3.5 Security Risk and Protection

Risk: A user may disclose credentials or download malicious content.

Protection: Verify the sender; inspect links; avoid unexpected attachments; verify requests through official channels; report suspicious emails.

Reference Basis: Authoritative cybersecurity guidance

Reference Paper / Standard: Relevant guidance or standard

Learning Video: Educational cybersecurity video

View Reference View Standard Watch on YouTube

2.4 Smishing

2.4.1 Definition

Smishing is phishing conducted through SMS or other text messaging services.

2.4.2 How It Works

An attacker sends a text that may appear to come from a bank, delivery company, service provider, or other trusted organization, often containing a link or request for information.

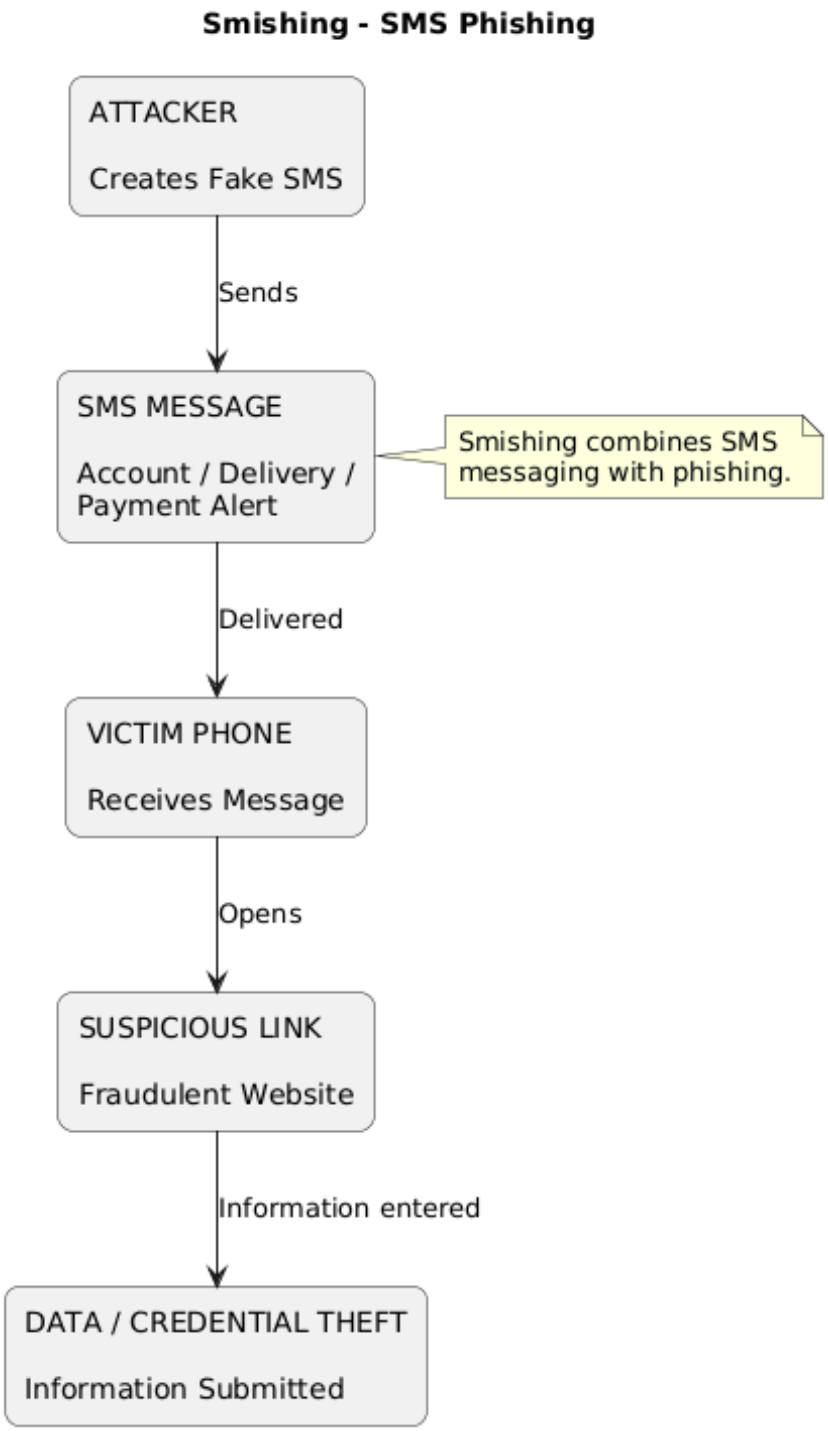


Figure 10: Smishing – SMS Phishing

2.4.3 Real-World Example

A user may receive a text claiming that a package cannot be delivered until a payment or address confirmation is completed.

2.4.4 Cybersecurity Connection

Smishing is important to mobile security because users may trust messages received on personal devices.

2.4.5 Security Risk and Protection

Risk: A victim may open a malicious link or submit credentials or payment information.

Protection: Do not trust unexpected messages; avoid suspicious links; verify through the official app/site; report suspicious messages; delete after reporting.

Reference Basis: Authoritative cybersecurity guidance

Reference Paper / Standard: Relevant guidance or standard

Learning Video: Educational cybersecurity video

View Reference View Standard Watch on YouTube

2.5 Vishing

2.5.1 Definition

Vishing, or voice phishing, is phishing conducted through telephone or voice communication.

2.5.2 How It Works

The attacker creates a believable urgent situation, such as a supposed security problem or payment issue, and asks the victim for sensitive information.

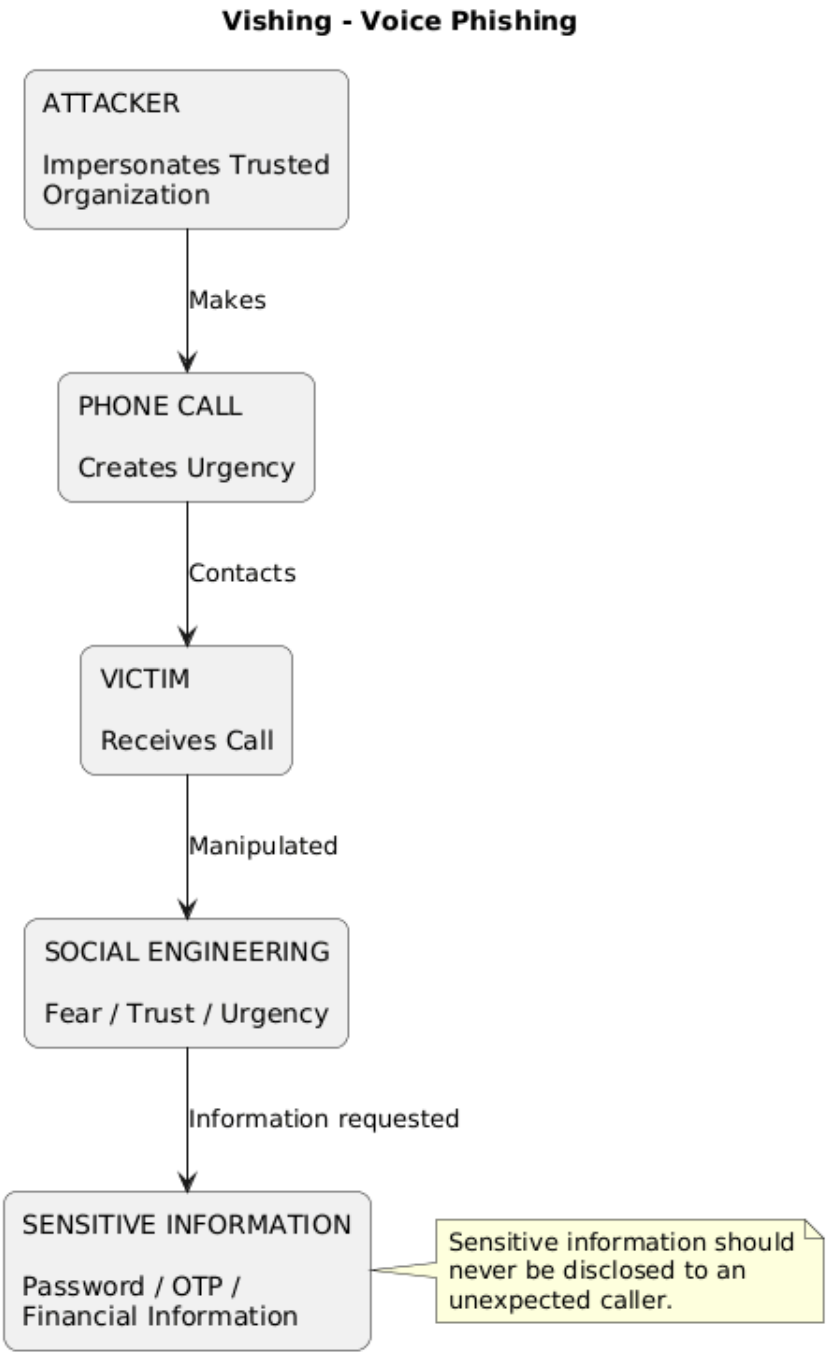


Figure 11: Vishing – Voice Phishing

2.5.3 Real-World Example

A caller may pretend to be from a bank's security department and ask for an OTP, password, or card information.

2.5.4 Cybersecurity Connection

Vishing demonstrates how social engineering can operate without malware or technical exploitation. Security awareness helps users recognize impersonation.

2.5.5 Security Risk and Protection

Risk: Victims may reveal credentials, financial information, or authentication codes.

Protection: Never disclose passwords or OTPs during unexpected calls; end suspicious calls; use official contact numbers; do not trust caller ID alone; report suspected fraud.

Reference Basis: Authoritative cybersecurity guidance

Reference Paper / Standard: Relevant guidance or standard

Learning Video: Educational cybersecurity video

View Reference View Standard Watch on YouTube

2.6 Fake Website / Link Phishing

2.6.1 Definition

Fake website or link phishing uses deceptive URLs or fraudulent websites that imitate legitimate services to collect credentials or other sensitive data.

2.6.2 How It Works

A deceptive link is distributed through email, SMS, social media, or another channel. The victim is directed to a fraudulent website that may visually imitate a legitimate service.

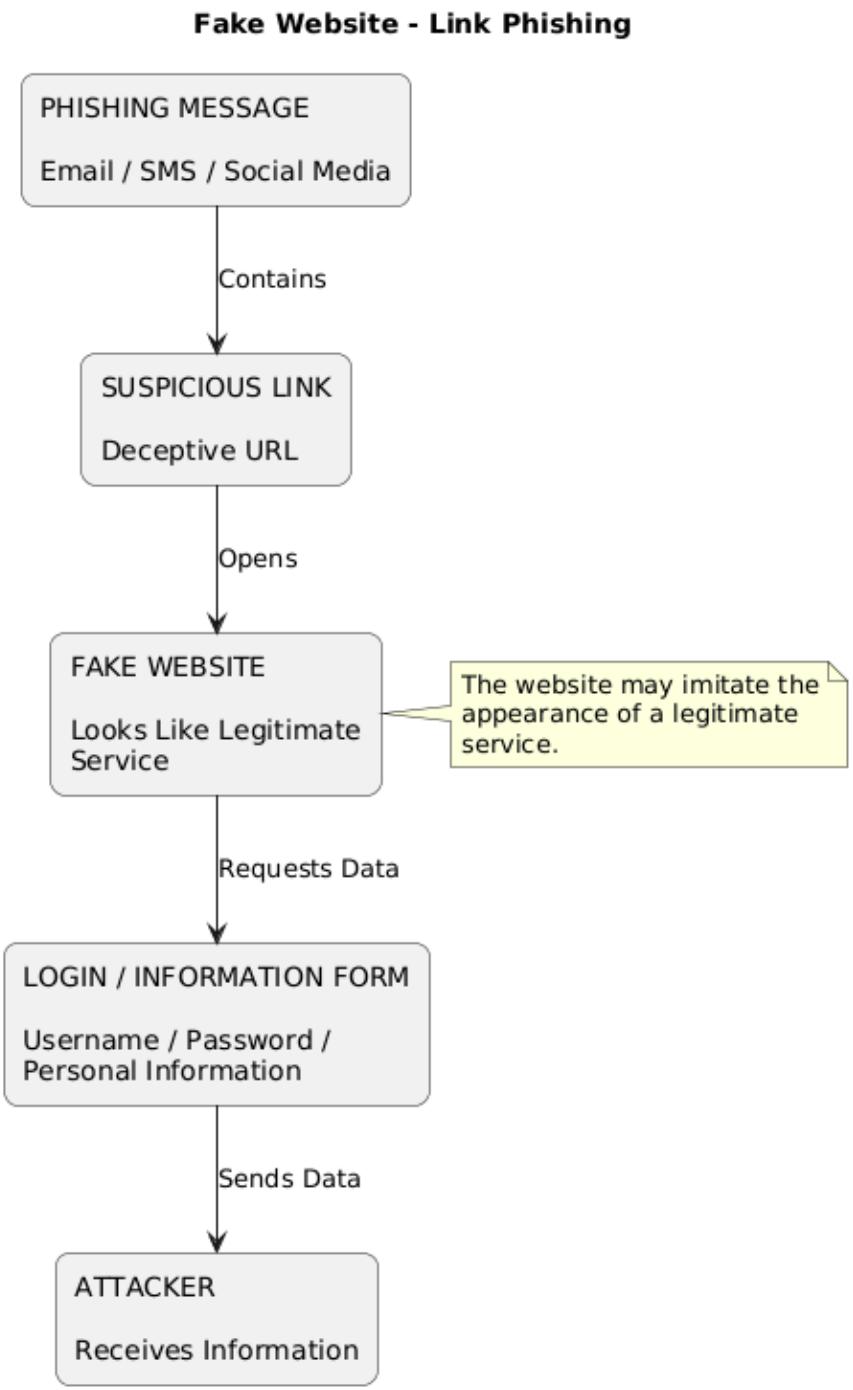


Figure 12: Fake Website – Link Phishing

2.6.3 Real-World Example

A phishing message may contain a link that appears to belong to an online service but leads to a fraudulent login page.

2.6.4 Cybersecurity Connection

Security teams can analyze URLs, domains, certificates, page content, and reported phishing indicators.

2.6.5 Security Risk and Protection

Risk: Entering credentials into a fraudulent website can give attackers access to an account.

Protection: Check the address carefully; avoid unexpected links; use known official websites/apps; enable multi-factor authentication; report fraudulent sites.

Reference Basis: Authoritative cybersecurity guidance

Reference Paper / Standard: Relevant guidance or standard

Learning Video: Educational cybersecurity video

View Reference View Standard Watch on YouTube

2.7 Five Common Signs of a Phishing Message

1. **Suspicious sender:** The sender address may not match the claimed organization.
2. **Urgent or threatening language:** The message pressures the recipient to act immediately.
3. **Suspicious link:** The URL may not match the expected organization.
4. **Request for sensitive information:** Passwords, financial information, or authentication codes may be requested.
5. **Spelling, grammar, or unusual content:** Errors, unusual formatting, or unexpected requests can be warning signs.



Figure 13: Five Common Signs of a Phishing Message

Reference Basis: Authoritative cybersecurity guidance

Reference Paper / Standard: Relevant guidance or standard

Learning Video: Educational cybersecurity video

View Reference View Standard Watch on YouTube

2.8 Phishing Types Comparison

Type	Channel	Common Technique	Typical Target
Email Phishing	Email	Fake messages, links, attachments	Credentials and sensitive information
Smishing	SMS / Text	Fake delivery, account, or payment messages	Mobile users and account information
Vishing	Voice / Phone	Impersonation and urgent requests	Credentials, financial information, OTPs
Fake Website / Link Phishing	Web / Links	Fraudulent websites and deceptive URLs	Login credentials and personal information

Table 2: Comparison of Common Phishing Types

2.9 Mini Practical / Try It Yourself

A safe phishing-awareness activity can be performed without interacting with a real phishing website.

1. Find a phishing-awareness example from NIST, FTC, or another recognized cybersecurity-awareness organization.
2. Examine sender information.
3. Identify suspicious links or requests without opening them.
4. Identify urgency, threats, or unusual wording.
5. Identify requests for sensitive information.
6. Record the warning signs.

Safety Note: Do not click suspicious links, download unknown attachments, submit personal information, or interact with real phishing websites.

2.10 Cybersecurity Connection

Phishing is important to cybersecurity because attackers can use social engineering to bypass technical controls by manipulating users. Security teams may use email security

gateways, spam filters, URL analysis, threat intelligence, endpoint security tools, and user reporting.

2.11 Security Risks and Protection

Risks: Credential theft, financial fraud, account compromise, malware infection, identity theft, and unauthorized access.

Protection: Stop and verify unexpected requests; do not click suspicious links or attachments; use multi-factor authentication; verify through official channels; report suspicious messages; keep devices updated.

Reference Basis: Authoritative cybersecurity guidance

Reference Paper / Standard: Relevant guidance or standard

Learning Video: Educational cybersecurity video

View Reference View Standard Watch on YouTube

2.12 Safe Response to a Suspicious Message

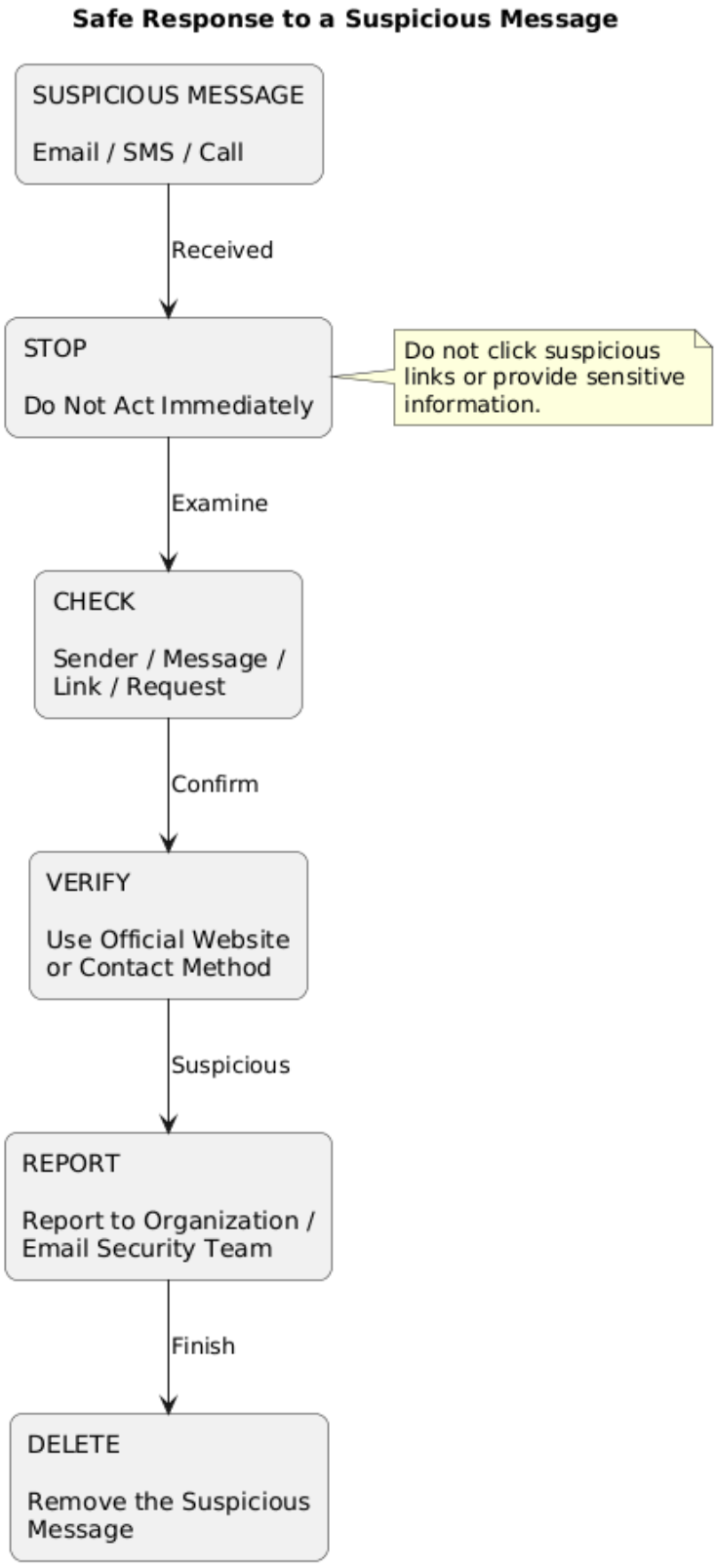


Figure 14: Safe Response to a Suspicious Message

2.13 Quick Check

1. What is phishing?
2. Why do attackers use phishing?
3. What is the difference between phishing and smishing?
4. What does vishing use?
5. Name five warning signs of phishing.

Answers:

1. A social-engineering attack using deceptive communication.

2. To obtain information, access, money, or deliver malicious content.

3. Smishing specifically uses SMS/text messages.

4. Voice or telephone communication.

5. Suspicious sender, urgent language, suspicious link, request for sensitive information, and unusual spelling/grammar/content.

2.14 Task 2 Summary

Phishing is a social-engineering technique that manipulates users into clicking harmful links, opening malicious content, or revealing sensitive information. Email phishing, smishing, vishing, and fake website/link phishing use different channels but share the objective of deceiving the victim. Recognizing common warning signs helps users avoid unsafe actions.

3 Task 3: Identify a Phishing Message

3.1 Introduction

Phishing messages are designed to appear trustworthy while attempting to persuade a recipient to click a link, open an attachment, provide sensitive information, or perform another action. A safe analysis should therefore focus on observable warning signs rather than on interacting with the suspicious message.

For this task, two publicly documented phishing examples from security-awareness resources were reviewed. The examples are used only for educational analysis. Suspicious links, attachments, phone numbers, and websites should not be opened or contacted during the analysis.

3.2 Phishing Message Analysis Process

A phishing message can be examined systematically by checking the sender, links, language, requested information, and other unusual content. After identifying the warning signs, the safest response is to verify independently, report the message when appropriate, and delete it.

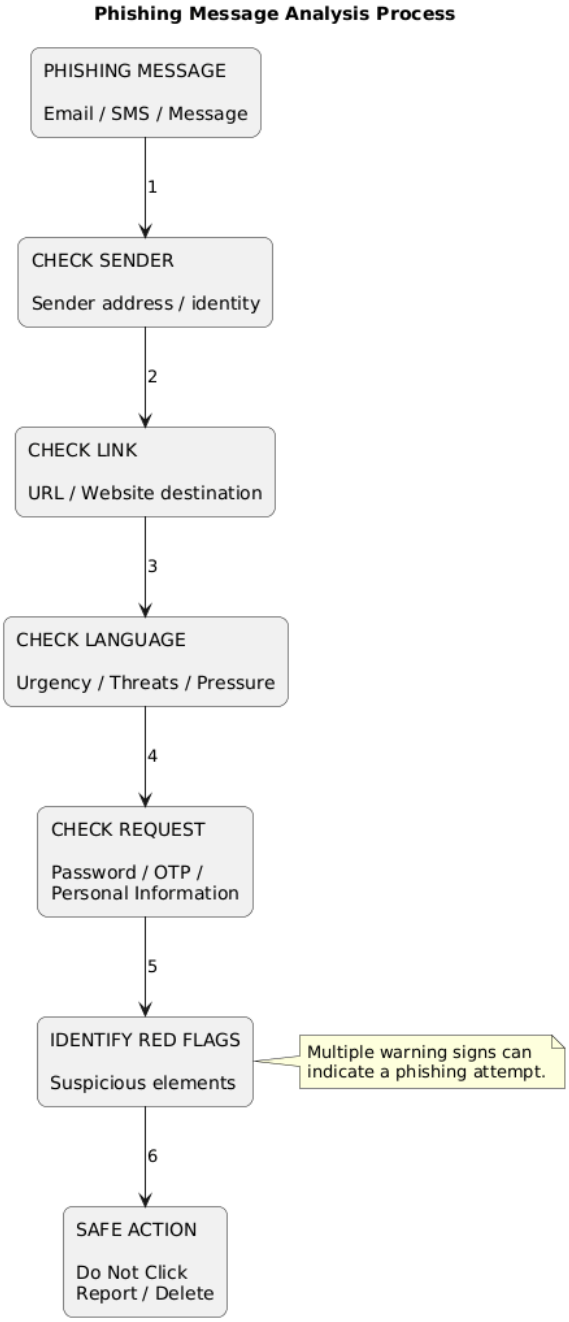


Figure 15: Phishing Message Analysis Process

3.3 Phishing Identification Checklist

The following checklist groups common indicators that can be reviewed without interacting with a suspicious message.

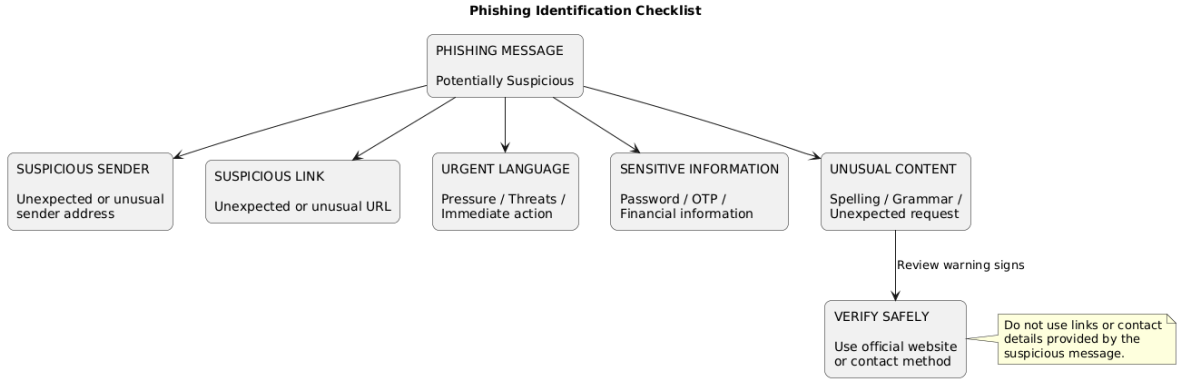


Figure 16: Phishing Identification Checklist

3.4 Public Example 1: Fake MetaMask Phishing Email

The U.S. Federal Trade Commission (FTC) published examples of fake MetaMask and PayPal messages. The MetaMask message falsely claimed that the recipient's cryptocurrency wallet was blocked and created pressure to act quickly by clicking a link and updating the wallet. The FTC warned that unexpected messages asking users to act quickly, click a link, or call a number are common phishing patterns.

Indicator	**Analysis**
Suspicious sender	The message impersonates a trusted service. The sender identity should not be accepted only because the message uses a familiar company name.
Suspicious link	The message asks the recipient to click a link to update or resolve the wallet problem. The link should not be opened.
Urgent / threatening language	It claims the wallet is blocked and suggests that the recipient must act quickly or risk losing cryptocurrency.
Spelling / grammar	Poor writing is not required for a message to be phishing. Modern phishing messages may be professionally written, so grammar alone is not a reliable test.
Request for personal information	The requested wallet update is intended to make the recipient interact with a fraudulent destination and potentially expose sensitive information.
Other suspicious element	The problem is unexpected and creates pressure to solve it through the message itself instead of independently verifying the account.

Table 3: Analysis of the FTC MetaMask phishing example

Why it should not be trusted: The message combines impersonation, urgency, and a request to click a link. A safer approach is to open the official service independently or use a known contact method instead of using information supplied by the message.

Reference basis: FTC, "Those urgent emails from MetaMask and PayPal are phishing scams."

https://consumer.ftc.gov/comment/181991

3.5 Public Example 2: Fake Direct-Deposit Phishing Email

NIST's phishing-awareness material includes a sample direct-deposit phishing email. The example appears to come from an individual and claims that the sender has changed banks and needs direct-deposit information updated before the previous account is closed. It creates pressure to provide assistance promptly.

Indicator	Analysis
Suspicious sender	The educational example shows an email from an address that does not provide sufficient assurance that the sender is really the person represented. Sender identity should be independently verified.
Suspicious link	The published description does not identify a specific embedded URL as the main indicator. The absence of a visible link does not make the request trustworthy.
Urgent / threatening language	The sender says the previous bank account will be closed in a few days and asks for prompt assistance, creating time pressure.
Spelling / grammar	The example is relatively well written. This demonstrates that correct spelling and grammar do not prove that an email is legitimate.
Request for personal information	The message attempts to obtain information related to direct-deposit banking details, which is highly sensitive.
Other suspicious element	A request to change payment or banking information should be independently verified through a trusted organizational process.

Table 4: Analysis of the NIST direct-deposit phishing example

Why it should not be trusted: A request involving salary or banking information is high impact. The recipient should verify the request using a known phone number, internal system, or previously established contact method rather than replying to the suspicious message.

Reference basis: NIST, "Phishing Cues-SOUPS Poster" – sample direct-deposit phishing email.

https://tsapps.nist.gov/publication/get_pdf.cfm?pub_id=956178

3.6 Comparison of the Two Phishing Examples

Indicator	Example 1: MetaMask	Example 2: Direct Deposit
Impersonation	Trusted cryptocurrency service	Individual / organizational identity
Pressure	Act quickly to avoid loss of cryptocurrency	Act promptly before an account is closed
Sensitive target	Wallet/account information	Banking and payroll information
Link involvement	Link requested to resolve the fake problem	No specific embedded link identified in the published description
Safe response	Independently verify the wallet/service	Independently verify through a trusted organizational channel

Table 5: Comparison of two publicly documented phishing examples

3.7 Cybersecurity Connection

Phishing is directly connected to identity theft, credential theft, malware delivery, financial fraud, and unauthorized account access. A successful phishing attempt can also become the first stage of a larger attack. Security awareness therefore acts as an important preventive control alongside technical controls such as spam filters, endpoint security, multi-factor authentication, and email protection.

3.8 Security Risks and Basic Protection

Major Risks:

- Theft of usernames, passwords, OTPs, and financial information.
- Installation of malware through malicious links or attachments.
- Account takeover after stolen credentials are reused.
- Financial loss and identity theft.
- Further compromise of an organization after an employee is deceived.

Basic Protection:

- Do not click unexpected links or open unexpected attachments.
- Verify suspicious requests using an independently known contact method.
- Use multi-factor authentication on important accounts.
- Report suspicious messages through the appropriate reporting mechanism.
- Delete phishing messages after reporting and documenting them when required.

Reference basis: CISA, "Avoid Phishing Scams with Three Simple Tips."

https : / / www . cisa . gov / sites / default / files / 2024-09 / Secure-Our-World-Phishing-Tip-Sheet.pdf

Reference / Standard: NIST, "Phishing" – Small Business Cybersecurity Guidance

https://www.nist.gov/itl/smallbusinesscyber/guidance-topic/phishing

Learning Video – S.No. 1: Professor Messer – Phishing and Social Engineering

https://www.youtube.com/results?search_query=Professor+Messer+phishing+social+engineering

3.9 Quick Check

1. Why should a suspicious link not be opened during analysis?
2. Name two common warning signs of a phishing message.
3. Why should a request for banking or password information be verified independently?
4. Is poor grammar required for a message to be phishing?

Answers

1. Because the link may lead to a fraudulent website or malicious content.
2. Examples include an unusual sender, suspicious link, urgent language, unexpected attachment, or request for sensitive information.
3. Because the message may be impersonating a trusted person or organization and could be attempting to steal sensitive information.
4. No. A phishing message can be professionally written, so grammar alone is not a reliable indicator.

3.10 Task 3 Summary

The two public examples demonstrate that phishing messages often rely on impersonation, urgency, unexpected requests, suspicious links, and attempts to obtain sensitive information. A safe analysis does not require interacting with the suspicious content. Instead, the message should be examined for warning signs and verified through an independent trusted channel.

4 Task 4: Malware Prevention

4.1 Introduction

Malware prevention combines technical controls, safe software habits, secure account practices, backups, and user awareness. No single control eliminates every malware risk, so several protective measures should be used together.

4.2 Malware Prevention – Overall Security Process

A basic prevention process begins with keeping the device updated and using security software. Trusted applications, safe downloads, careful handling of attachments, strong authentication, and backups further reduce the likelihood or impact of malware incidents.

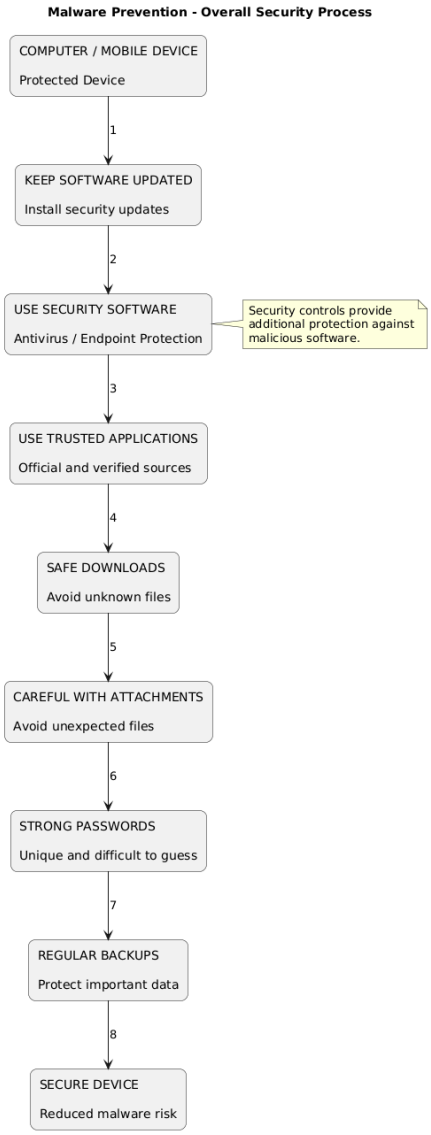


Figure 17: Malware Prevention – Overall Security Process

4.3 Ten Malware Prevention Practices

The following ten practices provide a practical baseline for reducing malware risk on computers and mobile devices.

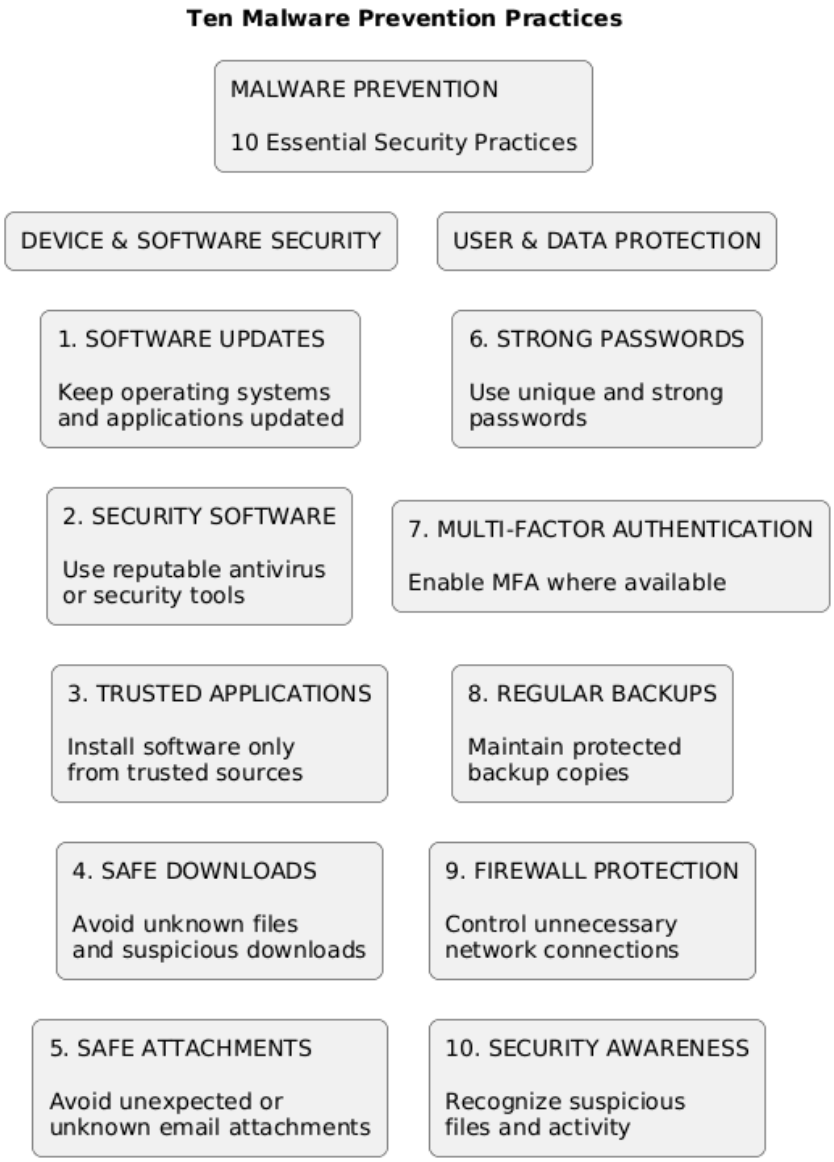


Figure 18: Ten Malware Prevention Practices

1. **Keep software updated** – Install operating-system and application security updates.
2. **Use security software** – Use reputable antivirus or endpoint protection where appropriate.
3. **Use trusted applications** – Install software from official or otherwise trusted sources.
4. **Use safe downloads** – Avoid unknown files and suspicious download websites.
5. **Be careful with attachments** – Do not open unexpected or suspicious files.
6. **Use strong passwords** – Use unique passwords or passphrases for important accounts.

7. **Enable multi-factor authentication** – Add an additional verification factor where supported.
8. **Maintain regular backups** – Keep protected copies of important data.
9. **Use firewall protection** – Control unnecessary network connections and exposure.
10. **Maintain security awareness** – Recognize suspicious files, links, prompts, and behavior.

4.4 Detailed Explanation of Five Practices

4.4.1 1. Keep Software Updated

Software updates frequently contain security fixes that address known vulnerabilities. Keeping the operating system, browser, applications, and security tools updated reduces exposure to vulnerabilities that attackers may attempt to exploit.

Practical action: Enable automatic updates where appropriate and regularly check for updates for software that does not update automatically.

4.4.2 2. Use Security Software

Reputable antivirus or endpoint-security software can help detect, block, quarantine, or remove malicious software. Security software is not a replacement for safe behavior, but it provides an additional layer of protection.

Practical action: Keep security software active and updated, and perform scans when suspicious behavior is observed.

4.4.3 3. Use Trusted Applications and Safe Downloads

Applications should be obtained from official stores, known vendors, or other trusted sources. Unofficial or modified installers can contain malware or unwanted software. Users should also verify the publisher and download source before installation.

Practical action: Check the official website or trusted app store, verify the publisher, and avoid suspicious download portals.

4.4.4 4. Avoid Unknown Attachments

Malware can be delivered through malicious email attachments and other unexpected files. A file that appears to be an invoice, document, or image may contain malicious content or direct the user to a harmful website.

Practical action: Verify unexpected attachments through a separate trusted channel before opening them.

4.4.5 5. Maintain Regular Backups

Backups reduce the impact of data loss caused by malware, accidental deletion, hardware failure, or ransomware. A useful backup strategy keeps copies protected from unauthorized modification or deletion.

Practical action: Back up important files regularly and periodically verify that the backup can actually be restored.

4.5 Malware Backup and Recovery Process

Backups are particularly important when malware causes data loss or makes files unavailable. A safe recovery process isolates the affected device, removes or rebuilds the compromised system, and restores data from a trusted backup.

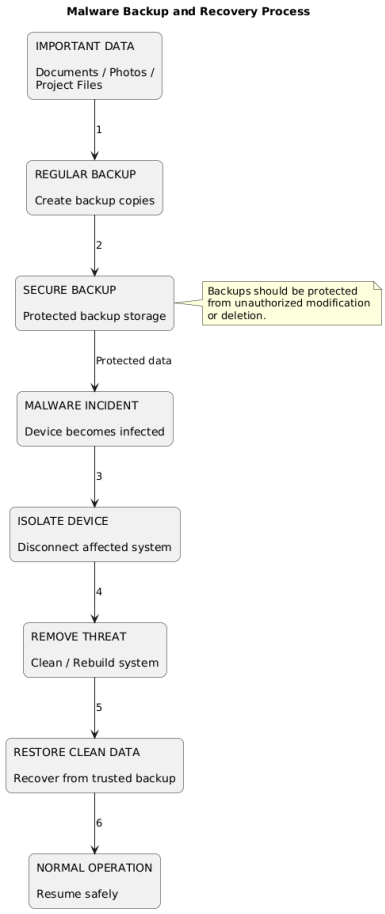


Figure 19: Malware Backup and Recovery Process

Important point: A backup that remains permanently connected and writable by the infected system may also be affected by malware. Backups should therefore be protected against unauthorized modification or deletion.

4.6 Safe Software Download and Installation

Software should be obtained from a trusted source and checked before installation. If the source is suspicious or cannot be verified, the safest action is to stop rather than continue with the installation.

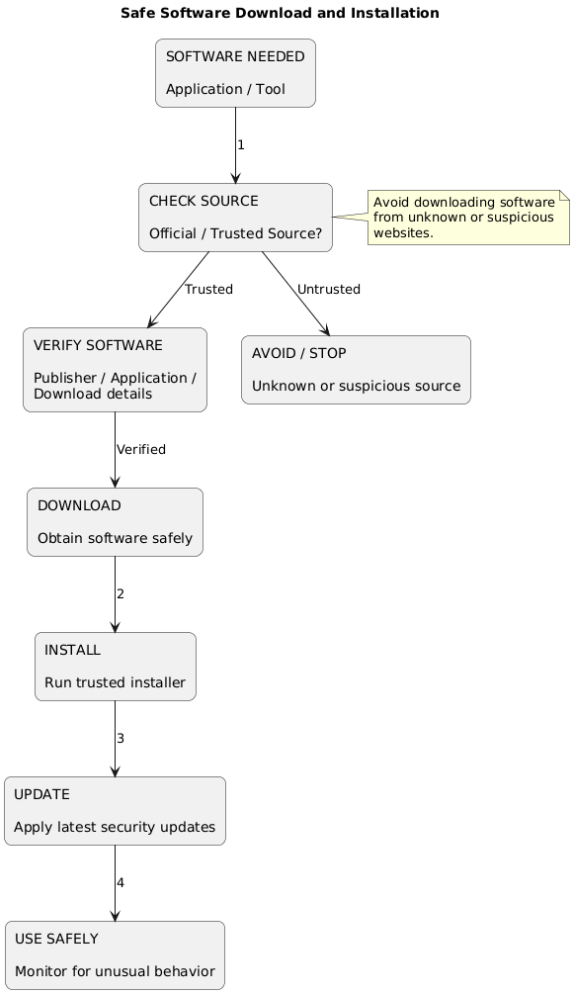


Figure 20: Safe Software Download and Installation

Reference basis: CISA, "Secure Our World – Malware and software security guidance."

https://www.cisa.gov/secure-our-world

Reference / Standard: NIST, "Cybersecurity Framework (CSF) 2.0" – protection, detection, response, and recovery concepts

https://www.nist.gov/cyberframework

Learning Video – S.No. 2: Professor Messer – Malware and Malware Prevention

https://www.youtube.com/results?search_query=Professor+Messer+malware+prevention

4.7 Cybersecurity Connection

Malware prevention is a layered security activity. Updates reduce known vulnerabilities, security software provides detection, trusted software sources reduce supply-chain and malicious-download risks, backups support recovery, firewalls reduce unnecessary exposure, and security awareness reduces unsafe user actions.

These controls correspond to the broader cybersecurity cycle of protecting systems, detecting suspicious activity, responding to incidents, and recovering from security events.

4.8 Security Risks and Basic Protection

Risk	Possible Impact	Basic Protection
Unpatched software	Exploitation of known vulnerabilities	Apply security updates
Malicious download	Malware infection	Use trusted sources and verify software
Malicious attachment	Malware execution or credential theft	Verify unexpected attachments before opening
Weak authentication	Account compromise	Use strong unique passwords and MFA
Data loss / ransomware	Loss or encryption of important files	Maintain protected backups
Unnecessary network exposure	Increased attack surface	Use firewall controls and secure configurations
User error	Unsafe execution or disclosure	Maintain security awareness and training

Table 6: Common malware risks and basic protection

4.9 Mini Practical: Safe Software Verification

A simple practical activity can be performed without downloading unknown software.

1. Select a commonly used application that is already installed or that you legitimately need.
2. Locate the official vendor website or trusted application store.
3. Check the publisher or developer name.
4. Compare the software name and version information with the official source.
5. Do not install the application if the source, publisher, or download details appear suspicious.

Security Note: The practical should not involve executing an unknown file or visiting a suspicious download site. The objective is to practice safe verification, not to test malware.

Reference basis: CISA, "Avoiding Social Engineering and Phishing" – safe handling of suspicious content.

https://www.cisa.gov/topics/cyber-threats-and-advisories/social-engineering

4.10 Quick Check

1. Why are software updates important for malware prevention?
2. Why should software be downloaded from trusted sources?
3. How can backups reduce the impact of ransomware or data loss?
4. Why are strong passwords and MFA useful against malware-related account compromise?
5. Why should unexpected attachments be verified before opening?

Answers

1. Updates can fix known security vulnerabilities that attackers may exploit.
2. Trusted sources reduce the chance of installing modified, malicious, or unwanted software.
3. Backups provide clean copies of important data that can be restored after an incident.
4. They make unauthorized account access more difficult, even if a password is exposed.
5. An unexpected attachment may contain malicious content or lead to further compromise.

4.11 Task 4 Summary

Malware prevention requires multiple layers of protection rather than one security tool. Keeping software updated, using security software, choosing trusted applications and downloads, handling attachments carefully, protecting accounts, maintaining backups, using firewalls, and developing security awareness all contribute to reducing malware risk.

4.12 Documentation References

1. CISA – Secure Our World and phishing-awareness guidance.
2. FTC Consumer Advice – phishing and scam-awareness guidance.
3. NIST – Phishing guidance and phishing-awareness examples.
4. NIST Cybersecurity Framework 2.0.

4.13 YouTube Learning References

1. Professor Messer – Phishing and Social Engineering.
2. Professor Messer – Malware and Malware Prevention.

5 Task 5: Security Awareness Scenario

5.1 Introduction

Security awareness helps users recognize suspicious messages before they become security incidents. Phishing attacks often rely on urgency, fear, impersonation, and requests for sensitive information. This scenario demonstrates how a user should respond when receiving a suspicious account-security message.

5.2 Security Awareness Scenario

Consider the following fictional message:

> **Account Security Alert**
>
> Your account will be permanently blocked within **24 hours** unless you verify your password. Please use the verification link provided in the message to confirm your account.

The message creates urgency and directs the recipient to take an authentication-related action through the provided link. The scenario represents a common social-engineering situation in which an attacker attempts to create fear of account loss and pressure the recipient into revealing credentials or visiting a fraudulent website.

5.3 Security Awareness Scenario Response Process

A safe response should stop the interaction first, identify the warning signs, verify the situation independently, and report the suspicious message through the appropriate channel.

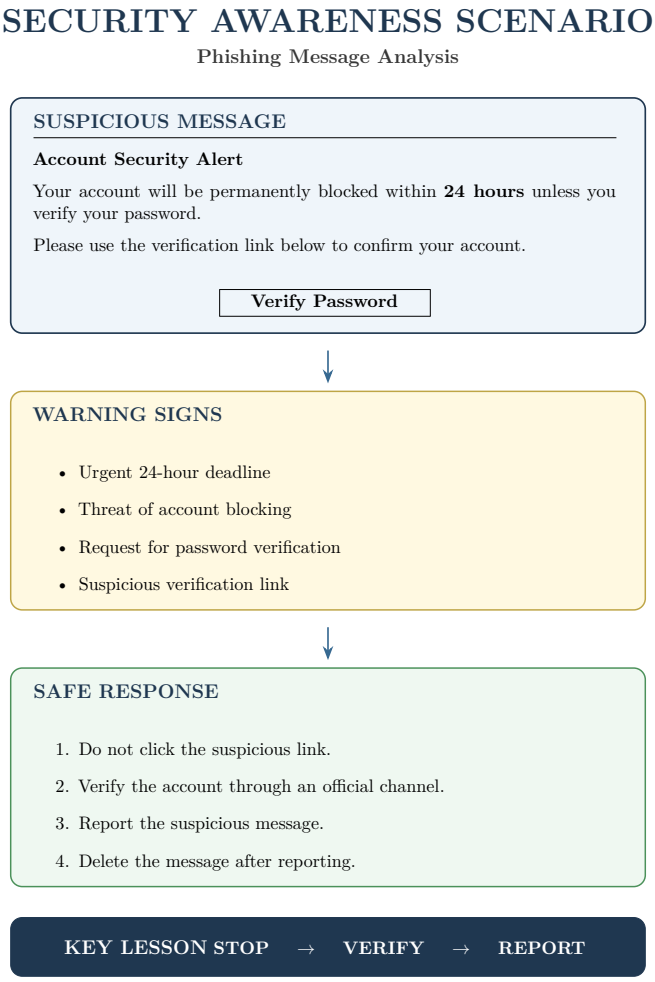


Figure 21: Security Awareness Scenario Response Process

5.4 What Type of Attack Is This?

The scenario is a **phishing attack using social engineering**. The attacker attempts to create urgency and fear of account loss so that the recipient will follow a malicious link and potentially disclose a password or other authentication information.

5.5 Warning Signs

1. **Urgent deadline:** The recipient is told that the account will be blocked within 24 hours.
2. **Threat of account loss:** The message uses a negative consequence to pressure the recipient.
3. **Password request:** A legitimate service should not require a user to disclose a password through an unexpected email link.
4. **Suspicious link:** The recipient is instructed to use a link supplied by the message rather than independently accessing the service.
5. **Unexpected authentication request:** The request concerns sensitive account information and should be verified before any action is taken.

5.6 What Should the Recipient Do?

- Do not click the link in the suspicious email.
- Do not enter a password, OTP, recovery code, or other sensitive information.
- Open the official application or manually enter the known official website address.
- Check the account status through the trusted service rather than through the email.
- If necessary, contact the organization using a previously known or independently verified contact method.
- Report the message through the organization's phishing-reporting mechanism.
- Delete the message after reporting and preserve relevant evidence if instructed by the organization.

5.7 What Should the Recipient NOT Do?

- Do not click the suspicious link just to see where it goes.
- Do not reply to the sender to verify the request.
- Do not provide passwords, OTPs, payment information, or recovery codes.

- Do not download or open unexpected attachments.
- Do not allow the deadline or threatening language to force an immediate decision.

5.8 Reporting Method

The suspicious email should be reported using the organization's established phishing-reporting procedure. Depending on the environment, this may be an email-security reporting button, a security operations mailbox, a help-desk process, or another approved reporting channel. The recipient should follow the organization's documented procedure rather than replying to the suspicious sender.

5.9 Cybersecurity Connection

This scenario demonstrates how security awareness supports technical security controls. A user who recognizes urgency, impersonation, suspicious links, and credential requests can prevent an initial phishing attempt from becoming credential theft or account compromise. In a security operations environment, reported messages can also provide indicators for investigation, filtering, and incident response.

5.10 Security Risks and Protection

Warning Sign	Possible Risk	Protection
24-hour deadline	Recipient acts without verification	Stop and verify independently
Account-blocking threat	Fear-based social engineering	Do not allow pressure to override verification
Password request	Credential theft	Never provide passwords through unexpected messages
Suspicious link	Fraudulent login page or malicious content	Access the official service independently
Unexpected email	Impersonation or unauthorized request	Confirm through a known contact method

Table 7: Warning Signs and Protective Responses in the Scenario

5.11 Mini Practical / Try It Yourself

Use a fictional phishing message and safely identify its warning signs without opening any suspicious links or attachments.

1. Identify the sender and determine whether the message was expected.
2. Look for urgent deadlines or threatening language.

3. Identify any request for passwords, OTPs, recovery codes, or payment information.
4. Inspect the visible destination of a link without opening it.
5. Record the warning signs and describe the safest response.

Safety Note: Do not click suspicious links, download unknown attachments, submit credentials, or interact with real phishing websites.

5.12 Documentation References

1. CISA – phishing-awareness and social-engineering guidance: https://www.cisa.gov/topics/cyber-threats-and-advisories/social-engineering
2. NIST – Phishing, Small Business Cybersecurity Guidance: https://www.nist.gov/itl/smallbusinesscyber/guidance-topic/phishing

5.13 YouTube Learning Reference

S.No. 5: Professor Messer – Social Engineering and Phishing Awareness.
https : / / www . youtube . com / results ? search_query = Professor + Messer + social + engineering+phishing

5.14 Quick Check

1. What makes the 24-hour deadline suspicious?
2. Why should the password-verification link not be used?
3. What is a safe way to check whether the account is actually at risk?
4. Where should the suspicious message be reported?

Answers

1. It creates urgency and pressure to act before the recipient can verify the request.
2. It may lead to a fraudulent website or other malicious content designed to steal credentials.
3. Access the official service independently through a known website, application, or trusted contact method.
4. It should be reported through the organization's approved phishing-reporting or security-support channel.

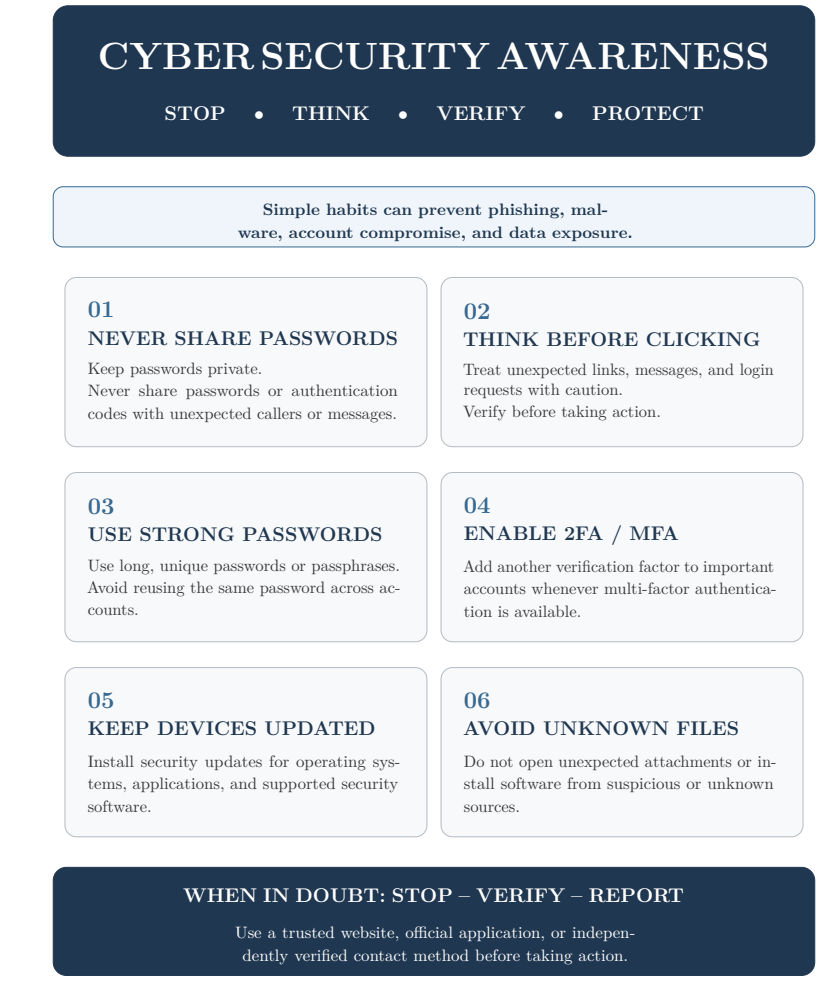
5.15 Task 5 Summary

The scenario shows how a phishing message can use urgency, threats, and credential requests to influence a recipient. The safest response is to stop, avoid interacting with the suspicious content, verify independently, report the message, and follow the organization's security procedure.

6 Task 6: Security Awareness Activity

6.1 Cyber Security Awareness Poster

The following poster presents practical security-awareness messages that can be applied to everyday computer and mobile-device use. The poster focuses on preventing common mistakes that can lead to account compromise, malware infection, or data exposure.



Security Awareness Activity — Think before you click, verify unexpected requests, and report suspicious activity.

Figure 22: Cyber Security Awareness Poster

6.2 Poster Safety Tips

1. **Do not share passwords:** Passwords and authentication codes should remain private.
2. **Be cautious with suspicious links:** Verify unexpected messages before clicking links.
3. **Use strong passwords:** Use unique passwords or passphrases for important accounts.
4. **Enable 2FA/MFA:** Use an additional authentication factor whenever the service supports it.
5. **Install updates:** Security updates help address known vulnerabilities in software and operating systems.
6. **Avoid unknown files:** Do not open unexpected attachments or install software from suspicious sources.

6.3 Why These Tips Matter

Security awareness is a preventive layer that helps users recognize and avoid unsafe actions. Password protection reduces credential exposure, MFA adds an additional authentication layer, updates reduce exposure to known vulnerabilities, and careful handling of links and files reduces common phishing and malware delivery paths.

6.4 Suggested Awareness Activity

The poster can be shared in a classroom, internship group, lab environment, or internal awareness channel. A participant can then be asked to identify which poster tip applies to a short security scenario, such as receiving an unexpected password-reset email, a suspicious attachment, or an unknown software installer.

Safety Note: The activity should use fictional or educational examples. It should not collect real passwords, OTPs, personal information, or credentials.

6.5 Cybersecurity Connection

Security awareness supports the human side of cybersecurity. Technical controls such as email filtering, endpoint protection, MFA, firewalls, and patch management are more effective when users also understand why safe behavior is required. Awareness activities therefore help connect individual actions with broader preventive and incident-response controls.

6.6 Quick Check

1. Why should passwords never be shared with another person?
2. What should you do before clicking an unexpected link?
3. What additional protection does MFA provide?
4. Why should operating systems and applications be updated?
5. Why should unknown attachments and files be treated cautiously?

Answers

1. Sharing passwords can expose accounts to unauthorized access and removes control over the credential.
2. Verify the message and destination independently before interacting with the link.
3. MFA provides an additional authentication factor beyond the password.
4. Updates can address known security vulnerabilities and improve security protections.
5. They may contain malicious content or lead to malware infection or other compromise.

6.7 Task 6 Summary

The awareness poster communicates six practical security habits: keep passwords private, think before clicking, use strong passwords, enable MFA, keep devices updated, and avoid unknown files. These simple actions can reduce common phishing, malware, and account-compromise risks and can be reinforced through regular security-awareness activities.

6.8 Documentation References

1. CISA – Secure Our World and phishing-awareness guidance.
2. FTC Consumer Advice – phishing and scam-awareness guidance.
3. NIST – Phishing guidance and phishing-awareness examples.
4. NIST Cybersecurity Framework 2.0.